

Scan the Skill, Govern the Action: Composing Registry Verdicts with Runtime Consequence Control

Rohit Taneja
Pheo Inc
rohit@pheo.ai

Travis Weber
Pheo Inc
travis@pheo.ai

Abstract

Agent skill registries screen what they publish. OpenClaw’s own security team published a careful measurement of that screening, reporting that its scanners overlap on at most 10.4% of combined positives and that 81.9% of flagged skills are caught by one scanner alone [1]. We take that finding as given, and suggest the interesting question it raises is not *which scanner is right* but *which question is being asked*. Each signal in that pipeline answers some form of “is this skill malicious?”, which is the question it is built to answer and answers well. A second question, “is this action permitted on this machine, by this operator, right now?”, is not one any of them is designed to express, and it has a different answer on the same artifact depending on whose infrastructure it runs on.

We report three measurements over 66,192 public ClawHub skill versions and a live agent. First, 705 skills across 135 distinct publishers that all three scanners and the registry’s own judge rate clean nonetheless instruct an action many operators forbid outright, an action named as prohibited by CIS Control 2.7 and NIST SP 800-53 CM-11. A hand audit of 100 of them puts our detector’s precision at 92% (95% CI [84.8%, 96.5%]) and found no marker of malicious intent in any correct detection. One publisher accounts for 506 of the 705, so the finding is 135 independent parties rather than 705 independent decisions, and we report all of these numbers rather than the largest. Permission and maliciousness are different predicates over the same artifact, and the pipeline computes the one it was built to compute. This measurement is reproducible end to end from public artifacts and we give the command.

Second, of 93 commands a live agent executed while following real skill documentation (40 skills, one agent), 3 appear verbatim in that documentation, and more to the point **36.6% had a consequence class that appeared in no code block of the document at all**. Static analysis reasons about a document that is an imperfect bound on what runs. We flag this one plainly: it drove a live model, we did not retain the harness or the per-command outputs, and a reader cannot re-derive it from what we publish.

Third, we set out what sits outside each layer’s view, including our own: a gate that reads actions does not see harm that never becomes one. Those gaps do not coincide, which is why we think the layers compose rather than compete.

We offer one design for a control point at that gap: a deterministic resolver (no model in the decision path; 67.6ms median end to end through the current CLI hook, almost all of it process spawn) feeding a per-(resource, class) trust ledger whose promotion thresholds are derived from an operator’s own stated risk tolerance rather than asserted. The common flat rule of “ten clean approvals” cannot exclude a true failure rate as high as 25.9% at 95% confidence, and demands 3–15× less evidence than the operator’s own stated policy requires. We argue agent-skill safety is a composition of two different questions, not a contest between two detectors, and we report where our own layer fails as precisely as where it helps.

1 Introduction

No bank checks a customer once. Know-your-customer runs at account opening: identity verified, source of funds established, sanctions lists cleared. It is a real control and a necessary one. Then the account opens, and a second control takes over that nobody would consider optional: every transfer afterwards is screened

as it happens, against limits, against patterns, against what this account has done before. No regulator would accept “we verified them at onboarding” as a complete answer, because the customer who was verified on day one is not a promise about the transfer attempted on day four hundred.

Agent skills today have the first control and not the second. Registries screen a skill before it is published, thoroughly, with several independent instruments, and then an autonomous agent installs it and begins acting on a real machine with real credentials, and no control asks whether any particular action is one this organisation permits. This paper is about the second half of that pattern: what it costs to be missing, and what it takes to build.

That a second control is required is settled rather than open, and a commercial tier has formed around it (§10). We take that as established. Our question is narrower: given that something must sit in front of every action, on what principled basis does it ever stop asking? A control that interrupts an operator on every consequential action converges on being switched off, and an operator who switches it off is less protected than one who never installed it.

An agent skill is a directory containing a `SKILL.md`: natural-language metadata describing when a skill applies, and instructions an agent follows once it does. ClawHub is the public registry through which most OpenClaw skills are distributed. Before a skill version is published, it passes a pre-catalog verification gate: independent scans from VirusTotal, in-house static analysis, and NVIDIA SkillSpector are handed as context to ClawScan, an LLM-as-judge harness that weighs them alongside provenance, metadata, and moderation history and issues one verdict: Clean, Suspicious, or Malicious [3]. The dataset records which model produced each verdict, and we report it from the data rather than from the vendor’s description: GPT-5.5 accounts for 99.47% of the 66,192 rows, with the remainder from `gpt-5-mini` (0.42%) and a `codex-security-worker` (0.10%) [2].

In May 2026 OpenClaw published a measurement of that pipeline which we treat as this paper’s premise rather than a finding to reproduce [1]. Across 67,453 skill versions, their three underlying scanners agree with each other almost never: any pair overlaps on at most 10.4% of combined positives, only 0.69% of flagged skills are caught by all three, and 81.9% of positives come from one scanner acting alone. Their diagnosis is precise, and we adopt it: *“we do not believe these findings point toward an issue with any of the individual scanners. Rather, each scanner has a different risk surface.”*

1.1 A second question about the same artifact

That diagnosis can be read as a detection problem: four instruments, four calibrations, unify them and the noise resolves. We think there is also something else going on, and it is not a criticism of any of the four. VirusTotal answers “is this a known-bad binary.” Static analysis answers “does this match a dangerous pattern.” SkillSpector answers “is this capability profile over-broad.” ClawScan, the judge over the three, answers “on balance, is this malicious.” Four well-posed questions, each answered by an instrument built for it, and all four about a property of the *artifact*.

Consider a skill published by `oomol`, whose documentation instructs:

```
curl -fsSL https://cli.oomol.com/install.sh | bash
```

Every signal in the pipeline calls this clean, and every one of them is right to: it is an ordinary vendor installer, published by a real company, and it is exactly what its documentation says it is. We use it as our running example precisely because there is nothing wrong with it. Yet many operators will not permit an autonomous agent to run it unattended, from any publisher, and the reason has nothing to do with this publisher or this script.

That premise is load-bearing for everything we count later, so we ground it in named controls rather than assert it. CIS Critical Security Control 2.7 requires technical controls ensuring that only authorised scripts execute, and directs that unauthorised scripts be blocked from executing [5]. NIST SP 800-53 CM-11 requires organisations to establish and enforce policies governing software installation by users, and names software of “unknown or suspect pedigrees” among prohibited installations [6]. CM-7 constrains systems to authorised functions. A shell command that fetches a script from the network and executes it in one step is, on its face, the execution of an unreviewed script of unknown pedigree.

We are describing what these controls say, not asserting an audit finding: we have not surveyed operators, and how any given assessor applies these controls to an autonomous agent’s shell commands is not settled

practice. What we claim is narrower and sufficient: for operators under these frameworks the question “is this action permitted here” has a different answer from “is this artifact malicious,” and the pipeline is built to answer the second. The prohibition is a property of the *action*, evaluated against *this operator’s policy*, not a property of the artifact.

A publish-time scanner is not the place to express that, and we would not expect it to be. Its output vocabulary is clean / suspicious / malicious. There is no slot for “acceptable at a two-person startup, prohibited at a bank,” because that judgment depends on facts, whose machine, whose data, whose compliance regime, what this skill has done here before, that do not exist at publish time and are not properties of the file.

1.2 Contributions

1. **Permission $\neq$ maliciousness, measured.** 705 skills across 135 distinct publishers that all three scanners and the judge rate clean while instructing an action named as prohibited by CIS Control 2.7 and NIST SP 800-53 CM-11 (§4). One publisher contributes 506 of the 705, so the count should be read alongside its distribution, which we give.
2. **The scanned artifact is not the executed artifact.** Of 93 commands a live agent issued while following real skill documentation, 3 (3.2%) appear verbatim in that documentation, and 34 (36.6%) carried a consequence class the document never contained (§5). Agent tool-use logging is well established; what we have not found measured elsewhere is the gap between what agent-skill static analysis inspects and what the agent then executes. This experiment is not reproducible from our released artifacts, for reasons we state where we report it.
3. **A small live demonstration.** A live agent, skills the registry had cleared, an unmodified gate, and four actions held or blocked before execution (§6). It is four cases out of 54 and we report it as a demonstration of the mechanism, not as a measurement of how often it matters.
4. **A layer-by-layer account of what sits outside each control’s view**, including our own, which is harm that never resolves to an action, stated as plainly as our contributions (§7).
5. **Derived, not asserted, autonomy thresholds**, parameterised by the operator’s own risk tolerance, with a measured resolver fast enough to sit on every tool call (§2.1, §8).
6. **A benchmark for action-level governance**, released with the paper: 64 semantics-preserving rewrites across nine techniques, with a stated scoring and aggregation rule, against which any implementation can report a resolution rate. Ours is 52% macro-averaged over techniques, 75% micro-averaged (§2.2). We are not aware of a shared way to state how much of an action’s equivalence class a gate covers, which makes it hard to compare two gates or to show that one is improving. We would rather publish a benchmark our own implementation only half passes than not have one.

2 OATS: Resolving Actions, Not Judging Artifacts

OATS (Open Agent Trust System) occupies the control point none of these signals sit on: the moment an agent has decided what to do and has not yet done it. It does not read the skill’s prose, and it does not render an opinion about the skill. It answers one question about one concrete act: *is an agent with this track record permitted to perform this class of action on this resource, unattended, under this operator’s policy?*

2.1 The deterministic resolver

Let Σ^* be the space of command strings an agent may emit and $\mathcal{C}$ a finite, closed set of consequence classes. $\mathcal{C}$ has 33 members, derived from the operations the governed surfaces expose rather than from a taxonomy chosen in advance: shell execution and its three dangerous specialisations (remote execution, credential access, destructive); file writes split by what the path implies (docs, tests, boilerplate, business logic, dependencies); repository and CI operations; secret and IAM changes; deploys; and the computer-use verbs. Rather than

enumerate all 33 in prose, we publish the set as a machine-readable file, `spec/action-classes.json`, one row per class carrying its key, its severity rank, and whether it can ever graduate. Thirteen of the 33 never graduate, and the rule is not a list but a threshold: a class graduates if and only if its severity rank is below 75 (§8).

The resolver is a function

$$\rho : \Sigma^* \rightarrow \mathcal{C}, \quad \rho(c) = \begin{cases} \max_{\preceq} \{ k \in \mathcal{C} : \pi_k(c) \} & \text{if some } \pi_k(c) \\ \text{shell_exec} & \text{otherwise,} \end{cases}$$

where π_k is the predicate for class k and $\preceq$ is the published severity order. We claim three properties for it, stated more carefully than in an earlier draft of this paper.

It is *total*. The second case is what makes it so: a command matching no predicate resolves to the generic `shell_exec` rather than to nothing, so no input path fails open. Without an explicit bottom element the maximum is undefined on the empty set, which is exactly the shape of the first defect in §9, where unmatched commands fell through as unclassified.

It is *stateless*. ρ reads the command string and nothing else: not the skill’s documentation, not the ledger, not the wall clock, not a model. This is a claim about ρ ’s inputs, not about functions in general, and it is the property that makes a decision replayable by an auditor without re-executing a model. We check it rather than assert it: 200 command strings classified in two independent ledgers with different histories returned identical classes in 200 of 200 cases.

One clarification a reader installing the client deserves, because they will meet it on first run. The published gateway does include a small local language model, which writes a plain-English description of what an agent changed. Its weights are not bundled in the wheel: they are fetched once from a public model repository and cached. It is not in the decision path. It runs asynchronously *after* the verdict has been computed and returned, it may fail or be absent without changing any decision, and it rewrites only the human-readable sentence attached to a decision already made. Keeping it out of that path is deliberate rather than incidental: a model placed there would be something an attacker could write a payload to argue with, and it would cost the property this section is about. The corpus study and the benchmark were both run with explanations disabled, which changes no class but removes the question. It implies $\rho(c)$ is identical across runs and hosts *within a release*. We do not claim stability across releases, and §9 reports three false-positive regressions in which $\rho(c)$ demonstrably changed for some c between releases. Every number in this paper is from `pheo-oats` 0.5.3.

One caveat on auditability that the interface currently imposes. The hook’s only output is a human-readable sentence, and both measurement scripts recover the class by string-splitting it. A reworded refusal message silently reclassifies, which is a poor foundation for a claim about replayability. The class set is published as `spec/action-classes.json` and both scripts now map through it, but the transport is still prose; emitting a stable machine-readable class identifier is the right fix and is not yet done.

It *resolves by maximum severity*. Where a command matches several classes the result is the most severe, not a union or a mean. We previously called this monotonicity, which names a different property; this is a definition, not a theorem. There is no score to tune and no threshold to drift.

Each π_k is argument-position-aware rather than keyword-presence-based: a token must occupy the position a dangerous argument would occupy relative to a specific command verb. The distinction is load-bearing: three successive false-positive regressions in our remote-execution predicate (§9) all had the same root cause: a gap in the pattern permissive enough to span markdown prose, section breaks, or an unrelated command chain, so that a URL mentioned in documentation hundreds of characters away from an `npm install` satisfied it. The shipped predicate bounds every gap explicitly and constrains it to characters admissible in a shell argument.

ρ takes no input from the skill’s documentation. A skill may describe its installation step as reassuringly as it likes; the description is not an argument to the function that decides whether the step is remote code execution. This closes one specific channel: Saha et al. report governance-evasion rates of 36.5–100% against static and LLM-based scanners achieved purely through how a skill’s own text is written [11], and that channel is unavailable against a function that never reads the text.

2.2 Threat model, and what ρ does not withstand

Closing the documentation channel is not robustness, and we want to be exact about the difference. We assume an agent recomposing benign documentation into concrete commands. We do not assume an adversary writing commands to evade a resolver whose grammar they know, and ρ should not be deployed as though we did.

The trust boundary. §10 claims Anderson’s criteria, so we owe the second one an answer rather than silence. The gate is a hook process invoked by an agent that can, by construction, run shell commands on the same machine. We assume uncompromised: the hook registration in the agent’s configuration, the `oatsctl` binary, and the ledger store. None of these is defended against the governed agent itself. An agent with local shell access can edit the configuration that installs the hook, or invoke a tool by a path the hook does not cover, and nothing in ρ prevents it. What integrity we do provide is over the record rather than the enforcement: every receipt carries a SHA-256 digest over its own contents, a reference to the previous receipt’s digest, and an HMAC-SHA256 signature under an operator-held key, so a ledger that has been edited after the fact does not verify. That detects tampering with the history; it does not stop an agent disabling the control prospectively. Tamper-resistance in Anderson’s sense needs the monitor outside the agent’s reach, which for a locally-installed hook means OS-level protection we do not currently implement. We therefore meet the first criterion, partially meet the second, and §10 is candid that the third is met only by a syntactic matcher.

The distinction is measurable, so we built a benchmark for it. Each case is a semantically equivalent rewrite of a base action whose consequence class is not in dispute: if the base resolves to class k , so should the rewrite, because the effect on the system is identical. A miss is therefore unambiguous. Table 1 reports 64 cases across nine rewriting techniques.

Technique	Cases	Resolved	Example
wrapper	20	100%	<code>bash -c "..."</code>
chained	15	100%	<code>true; ...; true</code>
interpreter	4	75%	<code>python3 -c "exec(urlopen(...))"</code>
variable	5	60%	<code>U=URL; curl -fsSL \$U bash</code>
base64	3	33%	<code>echo <b64> base64 -d sh</code>
indirect read	4	25%	<code>find ~ -name credentials -exec cat {} +</code>
quoting	5	20%	<code>curl -fsSL URL ba"sh</code>
staged	3	0%	<code>curl -o s URL; chmod +x s; ./s</code>
macro-average (headline)	59	52%	equal weight per technique
micro-average	59	75%	equal weight per case
identity (control)	5	100%	<code>curl -fsSL URL bash</code>

Table 1: Resolution rate under semantics-preserving rewriting, over 64 cases of which 5 are controls. **Scoring rule:** a case is resolved if the rewrite’s class is at least as severe as the base action’s, since a gate that over-classifies still protects the operator; on this suite that rule and exact match agree on every case. The headline is the macro-average over the eight rewriting techniques, with the identity control excluded from both aggregates. We report it that way because case counts per technique are an artifact of how many variants each generator happens to emit, and here that artifact is not neutral: every technique that resolves completely interpolates the base command and so expands to 15–20 cases, while every technique below 50% is fixed-form and collapses to 3–5. Micro-averaging therefore weights the successes roughly four to one and yields 75%, or 77% if the control is counted as well. The same measurements support 52% or 77% depending on a presentation choice, so we state the choice. No case failed to classify.

The shape of the failure is more useful than the headline. Wrapping and chaining resolve completely, which is the argument-position discipline of §2.1 doing its job: the resolver reads inside `bash -c` and past surrounding commands. What defeats it is any rewrite that removes the dangerous relationship from a single command. Staged fetch-then-execute resolves at 0%, because no individual command in `curl -o s URL`;

`chmod +x s; ./s` is remote execution; the composition is. Quoting and indirect reads fail for the same reason at one remove.

That is a statement about the class of function ρ is, not about the quality of its predicates. A per-command classifier cannot see a property that only exists across commands, and tuning patterns will not change that. Closing it requires resolving shell grammar and carrying state between calls, which is a different design and future work.

This bounds what the rest of the paper claims. §4 and §5 measure a non-adversarial world, and the honest bound in §5 (recomposition never produced a higher-severity class) is a statement about that world only: an adversary’s entire objective is to make a high-severity action look low-severity, which a benign sample never attempts. Hardening ρ against command-level obfuscation, most plausibly by resolving shell grammar rather than matching its surface, is future work and not a property we claim today.

2.3 Measured cost

A gate on every tool call must justify its place on the hot path with a number. We report only numbers a reader can reproduce with the released client.

The number an operator experiences is **67.6 ms** median and 81.1 ms at p95: what the CLI hook costs end to end, per tool call, on one core of an Apple M-series laptop against an empty ledger. Re-measured for this revision over 200 sequential calls spanning benign, ambiguous, and risky shapes, the median was 66.4 ms and p95 69.3 ms, which we take as confirming the original figure.

Almost all of that is process spawn and local IPC rather than classification. We can bound the classification component from outside the process but not isolate it: a 2,000-character command, the longest input the extractor admits and one dense with tokens every predicate must consider, costs 1.36 ms more end to end than a two-character one, and that difference also contains serialising a larger payload and storing a larger receipt. So resolution is under roughly a millisecond even at the largest input we accept, and far less at typical ones.

An earlier version of this paper reported resolution at 1.03 μ s mean and 3.27 μ s worst case, and derived throughput figures from them. Those came from an internal microbenchmark that is not part of the released code, whose iteration count and input distribution were not recorded, and which a reader therefore cannot rerun. We have removed them. They may well be accurate, and the bound above is consistent with them, but a number nobody can check should not be carrying an argument. Building a released benchmark for the resolver in isolation is straightforward and we have not done it.

A cost that is not on the hot path, and grows. The figures above are resolution and transport. They are not the whole cost, because every check also *writes*: a receipt, its digest, and its signature. Measured over the corpus run, each governance check adds roughly 12 KB to the gateway’s store, and per-check latency rises with the total size of that store rather than with the size of any one lane. Classifying into a single store, throughput fell from about 67 to under 20 classifications per second across the first 15,000 checks and kept falling; cycling the store held it flat at roughly 40–55/s. For an interactive agent this is invisible, because a developer does not issue 15,000 tool calls into one store. For corpus-scale evaluation it is the difference between a run that finishes and one that does not, and we had to structure our own measurement around it. We report it because it bears on the deployment claim: a gate cheap enough to sit on every action still has to keep a record of every action, and it is the record, not the decision, that scales badly. This is related to but distinct from the 152 MB read defect reported in §9, which was fixed; this one is a property of the current design and is not fixed.

The distinction matters for what is architecturally possible. A judge that consults a language model, local or hosted, pays a model’s latency on every decision, and that bounds where it can sit. The measured 67 ms, most of it process spawn we could remove by linking the resolver into a host process, is small enough to sit synchronously in front of every action without an operator noticing. We make no claim that ρ is smarter than an LLM judge; it is deliberately narrower (§7). We claim only that it is cheap enough, and stable enough, to occupy a position that a per-decision model call would make expensive.

2.4 The trust ledger

ρ 's output feeds a finite-state ledger keyed on the pair (resource, class), not on the skill. Trust is per-lane: a skill may be fully trusted to write documentation in one repository and permanently untrusted to read a credential file, at the same time. Each lane moves

$$unclassified \rightarrow held \rightarrow \begin{cases} approved & (\text{clean-run counter } n += 1) \\ rejected & (n \leftarrow 0) \end{cases}$$

with *graduated* reachable only when $n \geq N$, and only for the 20 classes whose severity permits graduation at all. Every transition is a counting rule over recorded human decisions, replayable from the ledger alone.

We should be exact about which half of this is shipped, because the paper's own argument makes the distinction matter. The never-graduates rule is implemented: 13 classes refuse promotion at any n , enforced in the authorisation path rather than configured. The threshold N is implemented as a *single operator-wide constant*, and its default value is 10. The per-class N_k derived in §8 is therefore a proposal about what that constant should be, not a description of what the shipped ledger does; parameterising N by class is work we have specified and not yet done. A reader is entitled to notice that the default we ship is the same flat 10 that §8 argues is 3–15× too permissive. That is a fair reading, and it is why we state the derivation as the paper's contribution and the constant as the implementation's current limitation rather than presenting the two as one thing.

3 Data and Method

We use `OpenClaw/clawhub-security-signals`, OpenClaw's own MIT-licensed dataset [2], in full: all four splits, 66,192 skill versions, each carrying four scanner verdicts and redacted `SKILL.md` content. (A dataset of the same name published by another account is a duplicate of this one; we use the `OpenClaw` path throughout. The premise study [1] reports 67,453 versions; the released dataset is the smaller 66,192 and we do not know what accounts for the difference.) Every skill is classified through the unmodified shipping client (`oatsctl hook pre-tool-use`), the same binary an agent's tool-use hook invokes, rather than a reimplementaion, for a reason documented in §9.

Counting, stated plainly. Every count in §4 is a count of *skills*. `skill_slug` is already unique in the published corpus, so no deduplication step is applied and none is needed. An earlier draft of this paper claimed we deduplicated findings by publisher and that raw counts were 2–3× larger. That was not what the released code did and we withdraw it: the code deduplicates nothing, and 705 is the plain skill count. We report the publisher count alongside it, and the per-publisher distribution in §4, so a reader can discount for a single vendor repeating one installer line across their own catalogue rather than take our word for how much that matters.

The corpus has no line breaks, and this bounds what can be measured. The sanitizer that produced the public dataset collapsed newlines: in all 66,192 rows, `skill_md_content` contains no newline character, and in 4.4% of rows they survive only as the two literal characters `\n`. Fenced blocks survive as `" "` delimiters, so we can still tell code from prose, but the boundaries *between commands inside a block* are gone. Two consequences run through everything below. First, we measure at skill granularity: does this skill instruct at least one action of class X . A block with five risky commands scores the same as one with a single risky command, so every count is a floor rather than an estimate. Second, and more seriously, “in a single command” is not a predicate this corpus can carry, because the separators that would define a command are exactly what was removed. An earlier draft of this paper claimed in its abstract that 657 skills fetch and execute remote code “in the same command.” On this corpus that is not something we can know, and we have withdrawn the phrase.

So we tested whether the finding depends on it. The worry is specific: if collapsing newlines makes an unrelated URL on one line textually adjacent to an unrelated `bash` on the next, the collapse becomes a false-positive generator. We checked by asking what syntactic shape each detection actually rests on. Of

the 674 blocks in the clean population resolved as remote execution, 587 (87.1%) contain an explicit pipe from `curl` or `wget` into a shell or interpreter, and 2 more use process substitution. A pipe character is not something a newline collapse can manufacture: it was in the author’s source line. A further 77 (11.4%) are single-token remote installs, `go install ...@version` (50), `pip install` from a URL or git reference (27), whose classification does not depend on adjacency at all. That leaves 8 blocks, 1.2%, resting on neither, all of them `npm install -g` against a remote target. So 98.8% of the detections rest on a construct that survives the sanitizer intact. The phrasing was wrong; the finding is not an artifact of it.

We also exclude one class, `secret_change`, from all risk counts, and we now report what that exclusion is worth rather than assert it. It fires correctly: a skill documenting a write to `.env` or `~/.config/.../credentials.json` genuinely is a secret operation, and nearly every skill requiring an API key does this, which makes it a correct classification and a weak risk signal. An earlier draft claimed including it would inflate the central finding by roughly 2×. On the corrected extraction that is false: including `secret_change` moves the count from 705 to 706, a factor of 1.00. The 2× was itself an artifact of the extraction defect in §9, which was feeding `.env` references out of ‘‘`json` and ‘‘`yaml` fences into a shell resolver. The exclusion is now nearly a no-op and we keep it only for continuity with the class’s documented rationale.

4 Finding: Clean Skills Instructing Forbidden Actions

Of 66,192 skills, 29,257 are rated `clean` by all three scanners and by the ClawScan judge. Within that population, 705 skills across 135 distinct publishers instruct an action in a class many operators forbid unattended (Table 2).

We report this population rather than the larger one available. Relaxing the condition to *no signal returned suspicious or malicious* admits a further 1,574 skills whose scans did not complete. The breakdown does not sum to 1,574 and we give the reconciliation rather than leave a reader to find that it does not: 731 have no Skillspector result, 438 no VirusTotal result, 393 no static result, and 45 an `unknown` ClawScan verdict, alongside 40 `stale`, 21 `error` and 3 `pending` states. Those are counts of signals, not of skills, and 62 skills are missing more than one, which is what closes the gap: 1,671 incomplete signals across 1,574 skills. That set yields 732 skills across 147 publishers, but “nothing objected” there includes “nothing looked,” which is a weaker claim than the one we want to make.

Action class instructed	Skills
Documented block fetching and executing remote code	658
Credential access	23
Destructive command	20
Merge to a protected branch	7
Trigger a workflow	1
Distinct skills (135 distinct publishers)	705

Table 2: Skills every scanner and the judge rated clean whose documentation instructs an action named as prohibited by the controls cited in §1. These are detections of policy-relevant capability, not of malice. Rows count class occurrences, not skills: four skills instruct two flagged classes and appear in two rows, so the rows sum to 709 against 705 distinct skills. Three never-graduating classes reachable from a shell command, `iam_change`, `deploy` and `delete_or_transfer_repo`, scored zero here; a zero is informative, so we say so rather than omit the rows silently. An earlier version of this table reported 20 IAM changes and 3 deploys, both of which were artifacts of the extraction defect in §9.

One publisher accounts for most of this. The headline is 705 skills, and a reader should immediately discount it, so we do the discounting here. The distribution across the 135 publishers is extremely skewed: the median publisher contributes *one* skill, 117 of the 135 contribute exactly one, and a single publisher, `oomo1`, contributes **506**, or 71.8% of the total. That is one company documenting one installer line, the same line quoted in §1, across its own catalogue of connector skills. Nothing about that is unusual or improper:

shipping a consistent install step across a product family is ordinary engineering practice, and it is the reason we chose that line as the running example. Excluding this publisher leaves 199 skills across 134 publishers.

We report all three numbers because they answer different questions. 705 is how many distributed artifacts would drive an agent toward the action. 135 is how many independent parties published such an instruction, and it is the right number for any claim about how widespread the *practice* is. 199 is what remains if a reader wants the finding without its single dominant contributor.

Because a concentrated count invites the reading that this is one vendor and a few copied templates, we checked. Restricting to remote execution and removing the dominant publisher entirely leaves 152 skills from 93 publishers, carrying 102 distinct command strings and fetching from 48 distinct domains. The magnitude of the headline depends heavily on one publisher; the practice it describes does not.

These 705 are flagged by our detector. We re-audited it by hand on this population: 100 skills drawn uniformly at random (seed fixed and published), each adjudicated against the question *does a fenced block in this skill actually instruct the flagged class*. 92 of 100 were correct detections, giving 92.0% precision with a 95% Clopper–Pearson interval of [84.8%, 96.5%] and 598–680 true positives among the 705. The eight errors are worth naming because they share a shape: five were a network fetch piped into an interpreter that only *formats* the response (`curl ... | python3 -m json.tool`, `curl ... | node -e` with a literal script), where nothing fetched is executed; two were `gh pr merge` resolved as a merge to a *protected* branch, which the document cannot establish; one was `npm install -g` of an ordinary registry package, which is a dependency change rather than remote execution. This supersedes the 73.6% figure reported earlier, which was measured on the pre-fix population and is not comparable. Audit limitations are in §9. What we take from this is that *maliciousness and permission are different predicates over the same artifact*. A publish-time pipeline answers the first, correctly and by design. The second is left for somewhere else in the stack, and at present there is not much of a somewhere else.

Are these skills benign? The argument above needs them not to be missed attacks, so we labelled the same 100-skill sample a second time, asking whether each skill showed any marker of malicious intent: exfiltration to a host unrelated to its stated purpose, obfuscated payloads, or behaviour the documentation does not disclose. None of the 92 correct detections did. Every one was an ordinary vendor installer, a language-toolchain install (`rustup`, `uv`, `go install ...@latest`), a published package, or a normal repository operation.

That is a real result and it is weaker than “these skills are benign,” which we are not in a position to claim. The audit was a single adjudicator reading documented code blocks, which is exactly the wrong instrument for finding a competent attacker, and 506 of the 705 come from one publisher, so the sample is dominated by repetitions of one installer line. More fundamentally, “rated clean” means nothing objected, not that anything verified benignity, and no scanner recall against this corpus is published (§9). What we can say is that we looked for the competing explanation, that a meaningful share of these are simply missed attacks, and did not find it in the sample. What we cannot say is that it is absent.

What this section measures, and what it does not. Two further limits bound the claim, and both are visible elsewhere in this paper, so we draw them here rather than let a reader find the tension unaided.

This is documented instruction, not observed execution. The measurement runs ρ over fenced code blocks in `SKILL.md`. Nothing is executed. That is the same document-based view §5 shows to be an imperfect proxy for what an agent runs, and the proxy is imperfect in both directions: a skill can document an action the agent never takes, and §5 finds the agent takes actions the document never contains. So 705 is a count of what skills *tell agents to do*. It is not a count of what agents did. Note also that §2.1’s “ ρ takes no input from the skill’s documentation” is a statement about deployment; in this section the documentation text is ρ ’s only input.

Instruction is not reach. §6 supplies the only bridge between the two, and it is narrow. On 54 unanimously-clean skills that instruct a risky action, a live agent reached for such an action in 4, or 7.4%. Composing that with the 92% precision above, the number of these 705 that would drive an agent to a forbidden action in a comparable run is on the order of $705 \times 0.92 \times 0.074 \approx 48$, not 705. We state the composition because a reader can compute it, and because the two rates measure genuinely different things: 705 is the size of the population a permission control would have to consider, and 48 is an estimate of how often it would have fired in one particular agent’s behaviour over four turns. The first is the right number

for scoping a control; the second, with a sample of 4 and the confidence interval in §9, is the right number for tempering claims about it.

5 Finding: The Scanned Artifact Is Not the Executed Artifact

Static analysis of `SKILL.md` is sound to the extent that the document’s capability envelope bounds what the agent executes. Nobody claims it requires string identity, so we measure both: how often the executed string appears in the document, and how often the executed *consequence class* does. The second is the one that decides whether the method is sound. For 40 skills sampled across distinct publishers, we classified every fenced code block in the document (the static view) and separately captured every command a live agent (Claude Sonnet 5) issued while following that same document, classifying both through the same resolver.

This one you cannot check, and we say so here rather than in a footnote. Unlike §4, this experiment is not reproducible from what we publish. It drove a live model, and we did not preserve the harness or the 93 per-command outputs in a publishable form. The numbers below are what we recorded at the time and we stand behind them, but a reader has only our word for them, and a rerun against a different model or on a different day would not reproduce them exactly in any case. We report it because we think the effect is real and worth knowing about, and we would rather present it with its provenance stated than either drop it or let it pass as though it carried the same weight as the corpus study. Re-running it with retained outputs is the most useful single thing we could do to this paper.

Executed commands ($n = 93$, 40 skills)	Count	Share
Verbatim from <code>SKILL.md</code>	3	3.2%
Recomposed (class present in document)	56	60.2%
Class absent from every documented block	34	36.6%

Table 3: What an agent actually runs, against what the document says. Read the two lower rows as the result: the executed string is almost never the documented string (96.8%), but the executed consequence class was absent from every documented block in 36.6% of cases. The second number is the one that bears on whether static analysis is sound.

Agents do not transcribe documentation; they recompose it. They chain a check onto an install the document never chained (`go version && go install ...`), add flags, redirect output, split one documented step into three. These 34 class-absent commands are not spread evenly: they concentrate in a minority of skills rather than appearing once in each.

Which number is the finding. 96.8% is a statement about string identity, and we report it because it bounds what any exact-match method can do: allowlisting documented command strings, hashing them, or diffing execution against the document would fail on almost every command an agent issues. It is not a claim that static analysis is blind, and presenting it as one would be a strawman. The claim the data supports is the narrower one: for 36.6% of executed commands the consequence class appeared in no code block of the document, so a reviewer reasoning about the document’s capability envelope would not have anticipated them. That is roughly a third the rhetorical size of 96.8% and it is the number we stand behind.

An honest bound on this result. All 34 unanticipated commands resolved to the generic `shell_exec` class. We observed *no* case in this sample where recomposition manufactured a *higher-severity* class than the document contained. The claim this experiment supports is therefore precise and narrower than it may first appear: the executed string is essentially never the documented string, so document-based analysis reasons about a proxy. But in this sample, the proxy did not fail in a dangerous direction. We report the absence of that stronger result because a reader would otherwise assume it.

6 Experiment: Live Runtime Verification

We ran a live agent (Claude Sonnet 5) against real skill documentation through the unmodified gate, executing only commands the gate permitted. Each skill received one run of at most four turns, with its `SKILL.md` in the system prompt and a single instruction to install it and confirm it works; a refused command returned the gate’s own refusal text as the tool result. As with §5, the harness and per-run outputs were not preserved, so the rates below rest on our record of the run rather than on anything a reader can re-execute. What is checkable is the other half of Table 4: all four skills are in the public corpus, and their verdicts, confidence levels, and the quoted rationales can be read from it directly. Across 54 unanimously-clean skills that instruct a risky action, the agent reached for such an action in 4 of 54 (7.4%, 95% CI [2.1%, 17.9%]); all four were held or blocked before execution (4 of 4, 95% CI [39.8%, 100%]). We report both rates: the first shows how often a cleared skill drives an agent toward a forbidden action, the second whether the gate stops it. The intervals are wide enough that neither rate should be quoted without them, and the second is consistent with a true block rate as low as 40%.

Three things this experiment does not establish. The turn budget may be producing the low reach rate rather than measuring it: four turns is a short budget for install-and-verify, and an agent truncated before it reaches the install step records as not reaching for the action. We have not tested a larger budget, and until we do, 7.4% is a floor on reach rather than an estimate of it. Second, we do not report a false-positive rate for the live gate. Case 4 in Table 4 is an ordinary install held for review, which is an intervention on a benign action; across the 54-skill run we did not record how often the gate held or denied something an operator would have permitted. That number decides whether a control survives contact with an operator, it is the failure mode §8 is written to address, and it is not measured anywhere in this paper. Third, the run is one agent, one model, one prompt.

Skill	ClawScan’s own verdict (verbatim)	What the gate did
minirr890112-byte/ llm-deploy-helper	clean, high confidence: “coherent and user-directed”	<code>pip install git+...</code> : denied, remote code execution
rogeecn/memos-cli	clean, high confidence: “a coherent Memos CLI helper”	<code>go install ...@latest</code> : denied
snuri00/osint-mcp	clean, medium confidence: “does not show malicious behavior”	<code>pip install git+...</code> : denied
charleshahn/ duivvytools-skills	clean, high confidence: “no hidden or abusive behavior found”	ordinary install held for review; retry via a third-party mirror denied

Table 4: Four live blocks, each on a skill the registry’s own judge had cleared, with its rationale quoted.

The fourth case shows the resolver reading an execution rather than a description. The agent’s first install attempt was ordinary and was *held for routine review*, not blocked. Its second attempt routed the same install through a third-party mirror, and the same resolver classified that occurrence as remote code execution and denied it. One documented step, two executions, two different classes, because ρ is a function of what actually happened, not of what the document said would happen.

7 What Each Layer Sees

The four registry signals and OATS are sometimes discussed as if they were competing detectors to be ranked by accuracy. We do not think they can be compared that way, because they do not take the same input, do not run at the same time, and do not emit the same kind of statement. Table 5 sets them side by side on those axes rather than on a shared score. Nothing in it is a criticism of any of them: the right-hand column records what sits outside each layer’s view by virtue of where it runs, and our own row is in the table for the same reason as the others.

Layer	Question it answers	Input	When	Outside its view
VirusTotal	Is this a known-bad binary?	Bundled files	Publish	Novel code; anything not in a signature database
Static analysis	Does this text match a dangerous pattern?	Document text	Publish	Intent; whether the pattern is ever reached
SkillSpector	Is this skill’s declared capability profile over-broad?	Document text, AI-assisted	Publish	Which capabilities are actually exercised, and on what
ClawScan	On balance, is this skill malicious?	The three above, plus provenance and moderation history	Publish	Anything absent from the artifact at publish time
OATS	Is <i>this action</i> permitted here, now, given this record?	The resolved command string	Every action	Harm that never becomes an action

Table 5: Five layers, five different questions. The right-hand column is the point: what falls outside a layer’s view follows from where it sits, not from how well it is built. Each of these is a capable instrument for the question in its second column.

The last column describes where each layer sits, not how well it performs. A reputation service does not recognise novel code, because reputation requires history. A capability review of a document cannot report which capabilities are actually exercised at run time, because that is not a fact about the document. And OATS does not see harm that never resolves to an action, because an action is the only thing it is ever shown.

That last limitation is ours and we state it plainly with examples rather than leave it implied. Reading the registry’s own summaries of skills it declined to clear, we find three recurring shapes that our resolver would have no way to notice. One is a hardcoded recipient: a skill that sends to an address fixed in the document, with no confirmation step, and with no executable block for a command-level gate to read at all. Another is a persuaded behaviour: a skill whose stated purpose is to automate an account while avoiding detection, assembled entirely from tool calls that are individually unremarkable. The third is an over-broad scope: an agent given far more access to private data than its purpose requires, where no single action is disproportionate and the mismatch only exists at the level of the whole skill.

We give these without naming the skills or their publishers, since the point is the shape of the harm and not any particular author. All three are what an artifact-level capability review, such as SkillSpector’s Excessive Agency analysis, is built to catch, and all three are invisible to a function that reads one command string at a time. A runtime action gate is not a superset of a semantic scanner and should not be deployed as one.

7.1 Why the blast radius is wider together

Because the blind spots do not coincide, the layers compose rather than compete. A skill can be malicious in the artifact and never act (caught upstream, invisible to us). It can be entirely benign in the artifact and still drive an action an operator forbids (invisible upstream, caught by us; §4 counts 705 such skills across 135 publishers). And an artifact that never changes can produce different actions on different runs, which is the case §5 measures at 36.6% and §6 exhibits concretely: the same documented install step resolved as ordinary on one attempt and as remote code execution on the retry.

An earlier draft supported this with a Jaccard overlap of 0.022 between OATS’s flags and the union of the registry’s positives, offered as evidence of independence. That was the wrong statistic and we withdraw the inference. Jaccard measures overlap, and for two events of very different base rates it is driven almost entirely by those rates; a low value is what you get from any pair of such signals regardless of how they depend on each other. Reporting it without the marginals also left a reader unable to tell which flag population was

used, and it was not the one §4 defines, which is disjoint from the registry’s positives by construction.

Here are the marginals and a statistic that measures association. Across the 66,192 skills, OATS flags $|A| = 1,412$ (2.13%); at least one registry signal returns suspicious or malicious on $|B| = 35,361$ (53.4%, almost all of it SkillSpector); and $|A \cap B| = 680$. Independence predicts 754 skills in the intersection, so the observed overlap is $0.90\times$ expected. The association is very slightly *negative*, not zero: $\phi = -0.016$, odds ratio 0.81, Fisher exact $p = 6.5 \times 10^{-5}$. The p -value is small because the corpus is large; the effect is negligible.

The honest reading is that we cannot establish independence, and do not need to. What the composition argument requires is only that the blind spots do not coincide, and that is a structural claim about what each layer takes as input (Table 5), not a statistical one. A ϕ of -0.016 is consistent with two instruments that are very nearly unrelated, which is what reading different objects would predict, and we take it as no more than that.

This suggests a composition rule that may be cheaper than building new detection: *a registry verdict is an input to the ledger, not a competitor to it*. Where an upstream evaluator has marked a skill non-clean, an operator’s policy can pin every lane for that skill at held or never-graduates, regardless of what ρ concludes about any individual command. The scanner’s artifact-level judgment and the gate’s action-level enforcement compose without either approximating the other. We present this as a mechanism rather than a measured result: evaluating it against the population that the scanner verdict itself defines would be circular.

Two predicates we built and did not ship. While examining what OATS misses, we implemented two candidate detectors, outbound data sent to a literal hardcoded domain and a credential embedded directly as a command argument, and held them to the specificity bar every shipped predicate must pass: measured false-positive rate against the 29,257-skill unanimously-clean population. They fire on 4.4% and 1.5% of clean skills respectively, because `curl`-POSTing data to a URL is simply how ordinary API integrations work. Either would manufacture, inside OATS, exactly the approval fatigue that makes this class of control hard to live with [4]. Neither shipped.

That is not the same bar the shipped predicates cleared. It would be convenient to say that it was, and it is not true. The shipped remote-execution predicate fires on 658 of the 29,257 unanimously-clean skills, or 2.25%, which sits between the 1.5% and 4.4% rates that disqualified the two candidates. Those two rates were measured before the extraction defect in §9 was found, so they are not strictly comparable to the 2.25% and we have no way to remeasure them: the predicates were never shipped and no longer exist. The ordering is unlikely to reverse, but a reader should treat the comparison as indicative. If the test were really the rate at which a predicate fires on clean skills, remote execution would plausibly have failed it. The actual distinction is precision: we believe the remote-execution firings are true positives and audited them at 92% (§4), while we never measured precision for either rejected candidate. That is a defensible reason to ship one and not the others, but it is a different reason, and comparing like with like would require an audit of the two we dropped, which we did not do.

For the same reason we now report base rates over the whole corpus rather than only the clean subset, since a signal that fires equally on both is not discriminating between them. Remote execution fires on 1.73% of all 66,192 skills and 2.25% of the 29,257 clean ones; credential access on 0.23% and 0.08%; destructive commands on 0.17% and 0.07%. Remote execution is, if anything, slightly *more* common among the skills every scanner cleared than in the corpus at large. That is not a defect in the signal. It is the paper’s thesis stated as a base rate: this predicate is not measuring maliciousness, and a population selected for being non-malicious does not have less of it.

When there is no verdict to compose with. Not every skill arrives through a registry. OpenClaw’s own roadmap acknowledges skills coming from GitHub, a private registry, or a file someone sends [4]. For those no upstream signal exists at any price, and the runtime layer is the only one.

8 Graduated Autonomy as Operator Policy

A gate that never lets a track record reduce scrutiny runs into a problem the field has already named, and which OpenClaw describes candidly in their published roadmap [4]: users enable unattended mode once prompts outpace reading, after which no prompt is read. We take that as an honest account of a difficulty everyone building these controls shares, ours included. A promotion rule has to be defensible, and “ten clean approvals” was chosen rather than derived.

Zero failures across N independent trials bounds the true failure rate ϵ at confidence $1 - \delta$ via $(1 - \epsilon)^N = \delta$, giving the threshold required for a class whose tolerable failure rate is ϵ_k :

$$N_k = \left\lceil \frac{\ln \delta}{\ln(1 - \epsilon_k)} \right\rceil.$$

This is the exact inversion of the one-sided binomial (Clopper–Pearson) bound at zero observed failures. It is often reached via the *rule of three*, the approximation $\epsilon \approx 3/N$ that follows from $-\ln(0.05) \approx 3$. We use the exact form throughout and call it by its own name. At $\delta = 0.05$, ten clean approvals leave a true failure rate as high as **25.9%** unexcluded. We state that carefully, because the number is easy to misread. It is a one-sided 95% upper confidence bound on ϵ : the largest failure rate ten clean trials cannot rule out. It is *not* the probability that the next action fails. The point estimate after ten clean runs is zero, and under a uniform prior the posterior predictive probability of failure on the eleventh is $1/12 \approx 8.3\%$. The case against a flat threshold of ten is not that the next action is likely to be wrong; it is that ten trials are too few to distinguish an agent that fails a quarter of the time from one that never fails.

Classes at this tolerance	ϵ_k	N_k	E[approvals]	× vs 10
Docs, tests, reads, issue/PR admin (8)	10%	29	202	2.9
Shell execution, boilerplate, screen interaction (5)	5%	59	392	5.9
Business logic, dependencies, merges, typed input (7)	2%	149	965	14.9
<i>illustrative: a stricter tolerance</i>	0.5%	598	3,807	59.8
Every class at severity ≥ 75 (13)	0%	never	—	—

Table 6: Clean runs required to license unattended action at 95% confidence, and the expected number of human approvals to actually reach that run given the reset in §2. **The grouping of classes into tolerance bands is our proposal, not a shipped configuration:** the implementation applies one threshold to every class (§2), and an operator adopting this table would be choosing these bands, not reading them out of the product. Under the grouping shown, a flat threshold of 10 demands 3–15× too little evidence; the 0.5% row prices a stricter tolerance an operator may choose, and no class is assigned to it. The bottom row is remote execution, credential access, secrets, destructive commands, deploys, IAM, CI configuration, workflow triggers, webhooks, repository deletion, protected merges, branch protection, and irreversible UI commits: no finite N licenses any of them. An earlier draft of this table placed deploys, IAM and CI configuration at $N = 598$, which contradicted the shipped policy that they never graduate at all.

Four things this derivation does not give the operator, stated because N_k reads more decisive than it is.

The trials are not independent, and they are not sampled from the population being licensed. An agent’s repeated actions on one resource are correlated, so N_k is a floor: dependence can only raise the evidence a sound threshold requires. The sharper problem is selection. The ledger counts *human-approved* runs, and graduation then removes the human. If the reviewer was catching and rejecting the bad cases, a clean run is evidence about the reviewer, not about the agent, and the reset to zero on rejection guarantees every counted trial is one a human passed. The quantity we bound is the failure rate *under review*; the quantity the operator needs is the failure rate *without it*. We know of no way to close that gap from the ledger alone, and we do not claim to.

A per-action bound is not a cumulative one. Bounding $\epsilon \leq 0.5\%$ says nothing about the probability of at least one failure across a period of unattended operation. At that bound, 1,000 unattended actions carry an expected 5 failures and a 99.3% chance of at least one. An operator who needs a failure budget per quarter should compute N from that budget, not read ϵ_k as a system-level guarantee.

There is no multiplicity correction. Each lane graduates at $\delta = 0.05$ independently, so an operator running 100 lanes should expect roughly 5 wrongly graduated and has a 99.4% chance of at least one. Either spend δ across lanes or accept that the guarantee is per-lane.

And the cost is the number of approvals, not N . Because a rejection resets the counter to zero, graduation requires N *consecutive* clean approvals, and the expected number of human approvals to reach a run of N at true rate ϵ is $(1 - p^N)/((1 - p)p^N)$ with $p = 1 - \epsilon$. The table above reports it: 202 approvals for documentation writes, 965 for business logic. This is the honest cost, and it is consistently 6–7 $\times$ larger than N . A section that opens by naming prompt fatigue has to concede where that leaves it: on high-frequency, low-consequence lanes, several hundred approvals is a plausible amount of work to amortise over months. On anything rarer it is not, and for those lanes this derivation is better read as documentation of what cannot responsibly be automated than as a route to automating it. Pooling evidence across resources within a class, or replacing the hard reset with a Beta-Binomial posterior that consumes a rejection without discarding history, would both reduce the cost; both weaken properties (§2’s per-lane isolation, and replay by counting) that we currently prefer to keep.

ϵ_k is the operator’s parameter, and it is where “what this organisation permits” enters the system as a number rather than a vendor default. A two-person startup and a regulated bank do not owe each other the same tolerance on a dependency change, and the same derivation tells each what their own stated tolerance costs in evidence. Classes in the bottom row admit no finite N , since no clean record makes an unrecoverable action recoverable, which is how the policy of §4 becomes mechanical.

9 Limitations and Defects in Our Own Instrument

Silver-standard ground truth, in both directions. OpenClaw’s dataset card describes `clawscan_verdict` as the registry’s automated verdict, not human-adjudicated truth, with a human-annotated subset still under development [2]. “Scanner-confirmed malicious” is not “verified malicious.” The symmetric point matters more for this paper: *“rated clean” is not “verified benign” either*. Clean means nothing objected. It does not mean anything established that these skills are harmless, and no scanner’s recall against this corpus is published, so we cannot bound how many genuinely dangerous skills carry a clean verdict. This bears directly on §4, whose argument is that the scanners are answering a different question rather than answering this one wrongly. If a meaningful share of the 705 were in fact missed attacks, that argument would weaken into “the scanners have false negatives,” which is a real result but somebody else’s and not the one we claim. An earlier draft asserted flatly that these were not missed attacks and that the scanners did not err. We had not measured that and have removed the assertion; §4 now reports what our audit does and does not establish about it.

Sample sizes. 54 skills for §6 and 40 for §5 demonstrate mechanisms and produce non-trivial rates; they do not support tight confidence intervals. §6 now carries them explicitly: 4 of 54 is [2.1%, 17.9%] and 4 of 4 is [39.8%, 100%].

We do not report a detection rate for OATS against malicious skills, by choice. Such a number would score a runtime action gate on a publish-time malware-detection benchmark, which is not the question it answers (§7); a favourable score there would in fact indicate redundancy with the scanners rather than value beside them. We describe the limitation qualitatively instead, in §7.

Precision, and the limits of how we measured it. §4 reports 92% precision from a hand audit. The protocol: 100 skills drawn uniformly at random from the 705 with a fixed published seed; for each, the fenced blocks that triggered the flag were read and judged against the question *does this skill’s documentation actually instruct the flagged class*, with a network fetch piped into a formatter, or a class the document cannot establish, counted as incorrect. The same sample was labelled a second time for markers of malicious intent.

The limitations are real. It is a self-audit: the authors adjudicating their own detector, with a single rater, so there is no inter-rater agreement to report. Some calls are genuinely arguable and we resolved them toward “correct”: a command that generates and prints a private key was counted as credential access though it reads no existing secret, and `rm -rf` against a build directory was counted as destructive though nothing unrecoverable is lost. A second adjudicator could reasonably return several points lower, so we report the sensitivity rather than only the point estimate: flipping all three arguable calls against us gives 89% ([80.8%, 94.3%]), and flipping twice that many gives 86% ([77.6%, 92.1%]). The interval [84.8%, 96.5%]

reflects sampling error only and not any of this. Precision is also not uniform across classes: with 658 of 709 class-occurrences in one class, the estimate is effectively an estimate for remote execution, and the rows with 23, 20, 7 and 1 occurrences are not separately supported by a sample of this size.

An earlier draft reported 73.6% precision without sample size, protocol, or interval. That figure was measured on the pre-fix population and we could not reconstruct its denominator; it is superseded rather than corrected.

No recall for the instruction detector. Separately from the deliberate choice below, we do not know what fraction of skills that *do* instruct a forbidden action our detector finds. The extractor reads only fenced blocks, ignores prose entirely, skips fences tagged as other languages, and measures at skill rather than command granularity, so 705 is explicitly a floor and not an estimate of the true population. Without a labelled subsample we cannot say whether it is 5% or 95% of it.

Single registry, frozen snapshot. One registry, one deliberately frozen snapshot chosen for reproducibility.

Nine defects in our own instrument, found and fixed during this work. A shell-classification bypass let unmatched Bash commands fail open. Three successive false-positive regressions in the remote-execution predicate, each a too-permissive gap, were caught only by measuring against the clean population. A performance defect fetched 152 MB of room history per governance check, which would have made corpus-scale evaluation impractical and any busy production room unusable. An entropy heuristic classified relative file paths (`references/CLAUDE-local-template.md`, 4.21 bits) as leaked credentials.

Three further defects were found in the measurement code after the first version of this paper circulated, and they are the reason §4’s numbers moved.

The extractor admitted non-shell code as shell. For a fence whose language tag was not a known shell, the guard deciding whether to keep it was applied to the body *with the tag still attached*. Ten common tags, `python`, `python3`, `node`, `go`, `cargo`, `docker`, `make`, `git`, `npm` and `jq`, are themselves command names, so the tag satisfied its own guard and every such fence was passed to a resolver written for shell. The fix keys on a fact that survives sanitization: an untagged fence’s body begins with the whitespace that followed the opening “`”, and a tagged one begins with its tag. On this corpus it moves 110,319 fences out of the shell population.`

Two never-graduating classes were structurally uncountable. The measurement script mapped the resolver’s prose labels back to class keys through a hand-written table carrying 15 of the 33 labels. `manage_webhook` and `delete_or_transfer_repo` were absent, so any occurrence of either was silently dropped and could never appear in Table 2. The taxonomy is now loaded from `spec/action-classes.json` rather than restated.

Errors were being silently discarded. Both measurement scripts invoked the classifier with `-fail-open` and wrapped it in a bare `except` that dropped any block which errored or timed out, with no counter. A block that failed to classify is not a block that classified as harmless, and the two were being pooled over an unknown denominator. Both scripts now run without `-fail-open` and report the failure count alongside every result. Relatedly, fence bodies are truncated at 2,000 characters, which was silent and is now counted: it affects 45 blocks in this corpus.

Two of the first six surfaced only when we ran the instrument across all 66,192 skills, which is the argument for corpus-scale evaluation. The three most recent surfaced when the measurement code was read adversarially by someone looking for them, which is the argument for publishing it.

10 Related Work

ρ is a reference monitor for agent actions, and the criteria are Anderson’s: invoked on every access, tamper-proof, and small enough to verify [7]. ρ sits on every tool call, admits no model into the decision path and replays from the ledger, and is a pure function of one string. Saltzer and Schroeder’s complete mediation and least privilege [8] are the same reasons the ledger is keyed on (resource, class) rather than on the skill. We claim no novelty in these principles, and none in applying them: our contribution is an implementation and a measurement, not a new idea about reference monitors. §2.2 is candid that the third criterion is currently met only by a syntactic matcher an adversary can route around, and §2.2 likewise concedes that we meet the second, being tamperproof, only partially.

Runtime guardrails for LLM applications are an active area. Llama Guard [9] classifies conversational input and output with a model; NeMo Guardrails [10] runs programmable rails over an application’s dialogue flow. Both put a model or a scripted policy between a user and a model. OATS sits one layer lower, between a model’s chosen action and the system it would change, and the difference that matters for deployment is cost: a rail consulting a model pays a model’s latency per decision, which is what confines it to conversational turns rather than every tool call.

OpenClaw’s scanner-disagreement study [1] is this paper’s premise rather than a comparison point. Saha et al. demonstrate discovery- and selection-manipulation attacks against ClawHub’s ranking and 36.5–100% governance evasion against static scanners [11]; their attacks target what a human or ranking algorithm sees before install, complementary to our focus on what an agent does after. Recent work on trajectory assurance argues individually permitted actions can jointly violate a state-conditioned invariant that no deployed mechanism enforces [12]; our per-(resource, class) ledger is one concrete instantiation of the enforcement point that work argues is missing, though we enforce per-action rather than per-trajectory. Formal machinery for temporal constraints over agent action sequences [13] is a natural direction for extending ρ ’s policy language beyond the per-action scope we implement.

Runtime governance as an emerging tier. The argument that agent safety requires a runtime control point is no longer only an academic position. A commercial category has formed around it: venture-funded platforms now discover agents across enterprise estates, record their tool invocations, and intervene on anomalous behaviour in production, at reported estate sizes in the thousands of agents. We take this as independent confirmation of the premise, and claim no part of the runtime tier as our invention; several of these systems do things ours does not. We do not cite a specific vendor deployment here, because we have not independently verified any and would rather cite nothing than cite a figure we cannot check.

It also helps locate what we think is still open. In the published descriptions we have read, of both registry-side scanning and this runtime tier, the decision offered to an operator is binary: an action proceeds, or it raises an alert and waits for a human. We have not found a published account of when scrutiny may be safely relaxed, though we would not be surprised to learn that one exists or that such logic is running in a product whose internals are not published. Absent it, the operator’s main recourse for reducing prompt volume is to turn the control down, which returns to the difficulty above. §8 offers one derivation of how much evidence a control should require before it stops asking. We put it forward as a starting point rather than a settled answer, and §8 is candid about what it does not give an operator.

11 Conclusion

OpenClaw’s measurement showed that agent-skill security is not one scanner’s allow/block call, and we agree. We suggest one reason is that a publish-time pipeline is built to compute maliciousness, while an operator also needs permission, which is a different predicate evaluated against facts that do not exist at publish time. The document those signals read is also only a partial bound on what runs: across 93 commands from 40 skills, 36.6% of what the agent executed had a consequence class absent from every code block of the document.

We offer one control point for that gap: a deterministic resolver cheap enough (67ms end to end, measured) to sit on every action, a per-lane trust ledger, and a derivation of promotion thresholds from the operator’s own stated tolerance rather than a vendor’s constant. We do not claim it is the only such design, or the best one, and we would be glad to be improved on. §2.2 is explicit about what this implementation does not withstand, and §2 about which parts of the design are shipped and which are proposals.

We are equally direct about the limit. A skill whose harm is a hardcoded recipient, an undisclosed scope, or a persuasive instruction produces no action for a gate to resolve, and no amount of policy strictness changes that. That is precisely the surface an artifact-level scanner reads and ours does not, which is the clearest argument we can make for why these layers belong together rather than in competition. Two candidate predicates that would have widened our reach failed our own false-positive bar and were not shipped. The measurements point the same way: scan the skill, and govern the action.

Availability

The corpus study can be re-derived from public artifacts; the two live-agent experiments cannot, and we set out which is which below rather than open with a claim that covers only part of the paper. An earlier draft opened this section with “every measurement here can be re-derived from public artifacts,” which was not true of §5 or §6. The corpus is OpenClaw’s own MIT-licensed dataset at <https://huggingface.co/datasets/OpenClaw/clawhub-security-signals>; the scanner-agreement figures quoted in §1 are two SQL queries in its own browser console. The profile, this paper, and the script reproducing §4 are at <https://github.com/pheo-ai/open-agent-trust-system> under Apache 2.0. That script runs the corpus through a released implementation rather than a private build, so the result does not depend on access to ours:

```
pip install pheo-oats pandas pyarrow requests
oats start --no-browser &
python research/reproduce_clawhub.py
```

This downloads roughly 1.6 GB and runs for several hours over the full corpus. The implementation used for every measurement here is `pheo-oats` 0.5.3, published for macOS, Linux, and Windows at <https://pypi.org/project/pheo-oats/>. The resolver’s decision path contains no model, so a rerun reproduces the same classes rather than approximating them.

What is not reproducible from this, and a disclosure. Three limits, and we would rather state them than have them found.

The resolver is not open source. `pheo-oats` is distributed under a proprietary licence, and an auditor can re-execute it but cannot read the predicates π_k . That is reproducibility by re-execution, not auditability, and it is a weaker claim than §10’s appeal to Anderson’s third criterion invites. We have published what can be published without the product: the full class set, severity order, and graduation policy as `spec/action-classes.json`, which is enough to check that a returned class is consistent with the stated ordering, and not enough to check that a given command should have produced it.

The harnesses for §5 and §6 are not in the repository, and an earlier draft of §6 said otherwise. Those two experiments drive a live model and were run from working scripts we did not preserve in publishable form; their per-command outputs are likewise not retained. They should be read as demonstrations we are reporting, not as measurements a reader can rerun. Only §4 and §2.2 are reproducible end to end.

Pheo Inc. develops and sells the implementation evaluated here. This paper evaluates our own product, against a bar we set, with no competing implementation measured alongside it. §2.2’s benchmark is released partly to make that comparison possible for someone other than us.

References

- [1] V. Koc, P. Erichsen, J. Tomlinson, A. Rivera, M. Appel, N. Paz. *ClawHub Security Signals: When VirusTotal, Static Analysis, and SkillSpector Disagree*. arXiv:2606.01494, May 2026.
- [2] OpenClaw. *ClawHub Security Signals* [Dataset]. <https://huggingface.co/datasets/OpenClaw/clawhub-security-signals>, 2026. MIT License.
- [3] V. Koc, P. Erichsen. *OpenClaw Collaborates with NVIDIA for Stronger Agent Skill Security*. OpenClaw Blog, June 1, 2026.
- [4] J. Merhi. *Where OpenClaw Security Is Heading*. OpenClaw Blog, May 15, 2026.
- [5] Center for Internet Security. *CIS Critical Security Controls*, Version 8.1, Control 2 (Inventory and Control of Software Assets), Safeguard 2.7.
- [6] National Institute of Standards and Technology. *Security and Privacy Controls for Information Systems and Organizations*. NIST SP 800-53 Rev. 5, controls CM-7 and CM-11, 2020.

- [7] J. P. Anderson. *Computer Security Technology Planning Study*. ESD-TR-73-51, USAF Electronic Systems Division, 1972.
- [8] J. H. Saltzer, M. D. Schroeder. *The Protection of Information in Computer Systems*. Proceedings of the IEEE 63(9), 1975.
- [9] H. Inan et al. *Llama Guard: LLM-based Input-Output Safeguard for Human-AI Conversations*. arXiv:2312.06674, 2023.
- [10] T. Rebedea et al. *NeMo Guardrails: A Toolkit for Controllable and Safe LLM Applications with Programmable Rails*. EMNLP 2023 System Demonstrations, arXiv:2310.10501.
- [11] S. Saha, F. Faghih, S. Feizi. *Under the Hood of SKILL.md: Semantic Supply-chain Attacks on AI Agent Skill Registry*. arXiv:2605.11418, 2026.
- [12] A. Lotfi, S. K. Shanto, I. Karim, E. Bertino. *Securing Agentic AI: From Per-Action Checks to Trajectory Assurance*. arXiv:2608.01558, August 2026.
- [13] A. Kamath, S. Zhang, C. Xu, S. Ugare, G. Singh, S. Misailovic. *Enforcing Temporal Constraints for LLM Agents*. arXiv:2512.23738, December 2025.